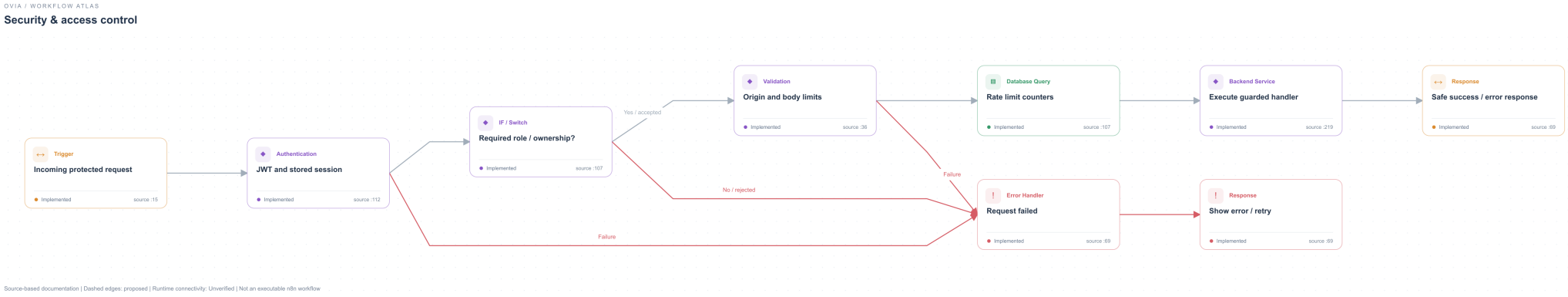
Security & access control

Architecture overview. Readable node and connection sheets follow.



Security & access control

Readable detail sheet 1/3. Node numbers and page references preserve every directed connection.

#01 / Trigger / Implemented

Incoming protected request

Applicable mutation handlers apply guards locally.

src/server/http.ts:15

Next -> #2 (p2)

#02 / Authentication / Implemented

JWT and stored session

Check HS256, issuer, audience, jti hash, session expiry and verified user record.

src/server/auth.ts:112

Next -> #3 (p2); Failure -> #8 (p3)

#03 / IF / Switch / Implemented

Required role / ownership?

Owner admin APIs use normalized OWNER/ADMIN; legacy staff routes have different literal role checks.

src/server/admin-auth.ts:107

Yes / accepted -> #4 (p2); No / rejected -> #8 (p3)

#04 / Validation / Implemented

Origin and body limits

Origin allowlist and streamed body cap are helpers explicitly called by participating routes.

src/server/http.ts:36

Next -> #5 (p3); Failure -> #8 (p3)

Security & access control

Readable detail sheet 2/3. Node numbers and page references preserve every directed connection.

#05 / Database Query / Implemented

Rate limit counters

limits collection tracks scoped counts in a sixty-second window; exceeding threshold returns 429.

src/server/http.ts:107

Next -> #6 (p3)

#06 / Backend Service / Implemented

Execute guarded handler

Handlers parse Zod input and authorize the applicable resource before service mutations.

src/app/api/v1/[[...path]]/route.ts:219

Next -> #7 (p3)

#07 / Response / Implemented

Safe success / error response

api() maps Zod to 400, duplicate records to 409, ApiError to its code, unknown service errors to 503; redacts environment secrets.

src/server/http.ts:69

END: no outgoing connection

#08 / Error Handler / Implemented

Request failed

Validation, access, conflict or service errors are returned to the caller. Status and error shape depend on the specific route.

src/server/http.ts:69

Next -> #9 (p4)

Security & access control

Readable detail sheet 3/3. Node numbers and page references preserve every directed connection.

#09 / Response / Implemented

Show error / retry

Failure end state. Caller receives the actual error; a retry may be offered by the UI.

src/server/http.ts:69

END: no outgoing connection

Security & access control

Complete directed connection register / no omitted success, failure or proposed edges

#01 Incoming protected request -> #02 JWT and stored session | Next

#02 JWT and stored session -> #03 Required role / ownership? | Next

#03 Required role / ownership? -> #04 Origin and body limits | Yes / accepted

#04 Origin and body limits -> #05 Rate limit counters | Next

#05 Rate limit counters -> #06 Execute guarded handler | Next

#06 Execute guarded handler -> #07 Safe success / error response | Next

#02 JWT and stored session -> #08 Request failed | Failure | FAILURE

#03 Required role / ownership? -> #08 Request failed | No / rejected | FAILURE

#04 Origin and body limits -> #08 Request failed | Failure | FAILURE

#08 Request failed -> #09 Show error / retry | Next | FAILURE

Note: Source implementation is documented; deployed configuration and provider connectivity are not verified.

Note: These protections are not universal middleware. API inventory lists checks found per handler; several routes use custom response/error wrappers. Broad origin allowances and inconsistent legacy role checks are documented review items, not silently corrected.